

Rapport de test d'intrusion — SAE 4.CYBER.01

- | **Cible** : 10.203.3.1 (filiale « Wichita MSWAD »)
- | **Position attaquant** : 10.203.0.176/16 (interface enp0s20f0u2)
- | **Date** : 2026-06-22
- | **Cadre** : exercice mutuel autorisé entre binômes, tests non destructifs
- | **Périmètre autorisé** : scan + énumération + test d'intrusion sans dégradation de service

Synthèse exécutive

La cible 10.203.3.1 présente une **surface d'attaque très réduite** : seuls 2 ports sont ouverts sur les 65 535 testés (HTTP 80 et RDP 3389). L'application web est une vitrine 100 % statique sans fonctionnalité dynamique exploitable. Le **cloisonnement réseau entre la DMZ et le LAN est efficace** : aucun accès direct au réseau interne n'a pu être établi depuis la position attaquant.

Aucune vulnérabilité critique n'a été identifiée. Les trois constats relevés sont de sévérité **faible à moyenne/haute**, dominés par l'**exposition du service RDP en frontal** et une **divulgation d'architecture interne** sur le site public. Le seul vecteur d'intrusion réellement résiduel est l'authentification RDP, dont le test est mis en attente de validation explicite (risque de verrouillage de comptes AD).

Indicateur	Valeur
Ports ouverts	2 / 65535
Vulnérabilités critiques	0
Vulnérabilités moyennes/hautes	1 (RDP exposé)
Vulnérabilités faibles	2
Cloisonnement DMZ/LAN	Efficace

1. Méthodologie

Approche en phases, non destructive :

- Découverte hôte (ICMP)

- Scan de versions des services courants (`nmap -sV -sC -T3 --top-ports 1000`)
- Scan exhaustif des 65 535 ports TCP (`nmap -p- --min-rate 1500 -T4`)
- Énumération de l'application web (en-têtes, contenu, JS, chemins)
- Test de cloisonnement (accès direct au réseau interne / DMZ)

2. Cartographie réseau (déduite par recon)

- Passerelle / point d'entrée : 10.203.3.1 (NAT/forwarding, TTL=64 → relai Linux)
- DMZ : 172.25.60.0/24 ; serveur web WEB-DMZ1 = 172.25.60.150 (IIS 10.0)
- Pare-feu : Stormshield (entre DMZ et LAN)
- LAN interne : domaine Active Directory, contrôleurs de domaine non exposés

3. Résultats

Ports exposés sur 10.203.3.1

Le scan exhaustif des 65 535 ports TCP **confirme** les résultats du scan ciblé : seuls deux ports sont ouverts, le reste répond `conn-refused`.

Port	Service	Version
80/tcp	HTTP	Microsoft IIS 10.0
3389/tcp	RDP	xrdp (Windows)

Validation : `nmap -p- (10:07)` → aucun port supplémentaire au-delà du top 1000.

Application web (port 80)

- Site 100 % statique (vitrine). Fichiers : `index.html`, `style.css`, `script.js`.
- Bouton « Accès administrateur » = simple `alert()` JS, non fonctionnel (cf. `script.js` : « Accès administrateur non activé pour le moment »).
- Aucun formulaire, aucune fonctionnalité dynamique, aucun endpoint caché trouvé.
- Méthode HTTP TRACE : signalée par nmap mais renvoie `501 Not Implemented` → **non exploitable** (pas de Cross-Site Tracing possible).
- Divulgaration d'information : la page publie l'architecture interne (plan d'adressage DMZ 172.25.60.0/24, IP du serveur, présence AD, pare-feu Stormshield) → fuite d'information utile à un attaquant (sévérité faible/moyenne).

Test de cloisonnement (DMZ / LAN)

- Accès direct à 172.25.60.150 sur 80/3389/445/22 : **tous filtrés/injoignables**.
- Ping 172.25.60.150 : 100 % de perte.
- ⇒ Le pare-feu cloisonne correctement. Aucun accès direct au réseau interne depuis l'extérieur.

4. Vulnérabilités / observations

#	Constat	Sévérité	Recommandation
1	RDP (3389) exposé en frontal sur la passerelle	Moyenne/ Haute	Restreindre RDP à un VPN/VLAN admin, activer NLA, MFA, comptes limités, politique de mots de passe forte
2	Divulgaration d'architecture interne sur le site public	Faible	Retirer IP / plan d'adressage / technologies du contenu public
3	HTTP en clair (pas de TLS)	Faible	Mettre en place HTTPS (redirection 80 → 443, HSTS)

5. Points positifs (défense efficace)

- Cloisonnement DMZ/LAN opérationnel : pas d'accès direct au réseau interne.
- Serveur web non joint au domaine AD (limite la propagation latérale).
- Surface d'attaque réduite (2 ports seulement sur 65 535).
- Application web sans logique côté serveur (pas d'injection, pas d'upload, pas d'auth).

6. Vecteur d'intrusion résiduel

Le seul service réellement exploitable exposé est **RDP sur 10.203.3.1:3389**. Toute tentative d'accès au LAN passerait par la compromission de cet accès, puis un pivot.

Mise en attente — décision requise. Un test d'authentification RDP (bruteforce / password spraying) peut provoquer des **verrouillages de comptes Active Directory** = impact de service. Cette étape ne sera **pas** menée sans validation explicite du commanditaire et un bornage strict (comptes de test dédiés, seuils de tentatives connus, fenêtre horaire convenue).

7. Conclusion

Le périmètre exposé de la filiale Wichita MSWAD est **correctement durci** : surface réduite, cloisonnement fonctionnel, absence de service applicatif vulnérable. Les améliorations recommandées relèvent du **durcissement** (filtrage RDP, suppression de la fuite d'information, passage en HTTPS)

plutôt que de la correction d'une faille critique. En l'état, aucun chemin d'intrusion non destructif n'a permis d'atteindre le réseau interne ; le vecteur RDP demeure le seul axe d'investigation restant, sous réserve d'une autorisation et d'un bornage explicites.

Annexes — fichiers de preuve

Fichier	Contenu
<code>scan_10.203.3.1_20260622_0948.txt</code>	Scan nmap -sV -sC top 1000
<code>fullscan_tcp.txt</code>	Scan exhaustif des 65535 ports TCP
<code>web_enum.txt</code>	En-têtes HTTP + extrait page d'accueil
<code>web_enum_index.html</code>	Copie de la page d'accueil
<code>script.js</code>	JavaScript du site (bouton admin non fonctionnel)